Повышение квалификации специалистов по информационной безопасности

КОНСПЕКТ ЛЕКЦИИ 1

по курсу
«Методы и принципы проектирования современных защищённых систем. Применение механизмов искусственного интеллекта для анализа данных при построении систем информационной безопасности»

ПРОЕКТИРОВАНИЕ ЗАЩИЩЁННЫХ СИСТЕМ

Активы, границы доверия, нарушитель, угрозы, требования безопасности

(2 академических часа)

2026

СОДЕРЖАНИЕ

Введение 4

1 Свойства безопасности и принципы проектирования 6

1.1 Свойства безопасности 6

1.2 Принципы проектирования 7

1.3 Защита в глубину 8

1.4 Нарушения принципов в реальных инцидентах 9

2 Активы и поверхность атаки 10

2.1 Активы 10

2.2 Поверхность атаки 11

2.3 Сокращение поверхности атаки 12

3 Границы доверия и диаграмма потоков данных 13

3.1 Границы доверия 13

3.2 Диаграмма потоков данных 13

4 Модель нарушителя и угрозы 15

4.1 Модель нарушителя 15

4.2 Сценарии атак 16

4.3 Классификация угроз STRIDE 17

4.4 Оценка рисков 18

5 Архитектура нулевого доверия 20

5.1 Предпосылки 20

5.2 Положения архитектуры нулевого доверия 20

5.3 Компоненты архитектуры 21

5.4 Применение к учебному магазину 22

6 Требования безопасности 23

6.1 Источники требований 23

6.2 Стандарт OWASP ASVS 23

6.3 Формулировка требований 24
6.4 Процесс моделирования угроз 25
Заключение 27
Список использованных источников 28
Приложение А Вопросы для самопроверки 30

ВВЕДЕНИЕ

Сл. 1, 2

Лекция посвящена проектированию защищённых систем: порядку рассуждений, при котором безопасность закладывается в архитектуру до написания кода, а требования безопасности формулируются до начала реализации и проверяются на каждом этапе жизненного цикла системы. Причина такого порядка в том, что серьёзные уязвимости чаще возникают из архитектурных решений, принятых или не принятых в начале, чем из ошибок в отдельных строках кода [1]: ошибку в архитектуре нельзя исправить заплаткой, её исправление требует переработки системы.

Примером служит утечка данных компании Equifax в 2017 году: через неисправленную уязвимость в библиотеке Apache Struts были получены сведения примерно о 147 миллионах человек, и Федеральная торговая комиссия США указала в числе причин отсутствие должного контроля за установкой исправлений [2]. Процессы инвентаризации систем и установки исправлений относятся к проектированию, а не к программированию, поэтому их отсутствие нельзя было восполнить на этапе кодирования.

Для иллюстрации всех шагов в лекции используется один учебный пример — интернет-магазин. Покупатели работают с ним через браузер, администратор управляет каталогом и заказами, веб-приложение хранит данные в базе данных и передаёт платежи внешнему платёжному сервису. В каждой главе к магазину применяется очередной шаг, а в конце лекции из него складывается итоговая таблица угроз и мер.

Материал лекции выстроен как цепочка шагов, каждый из которых даёт исходные данные для следующего (таблица 1). Сначала определяются свойства, которые требуется защитить, и принципы проектирования; затем выявляются ценные объекты системы (активы) и точки, через которые к ним можно обратиться; затем границы, при пересечении которых меняется уровень доверия; затем тот, кто может атаковать, и то, что он может сделать; после этого строится архитектура с проверкой каждого обращения и формулируются проверяемые требования.

Таблица 1 — Последовательность проектирования защищённой системы

Глава	Вопрос	Результат
1	Что защищаем и по каким правилам проектируем?	Свойства безопасности и принципы проектирования
2	Какие объекты ценны и где к ним можно обратиться?	Перечень активов и поверхность атаки
3	Где меняется уровень доверия?	Диаграмма потоков данных с границами доверия
4	Кто и как может атаковать?	Модель нарушителя, перечень угроз, оценка рисков
5	Как проверять каждое обращение?	Архитектура нулевого доверия
6	Как записать меры проверяемо?	Требования безопасности и таблица угроз

1 Свойства безопасности и принципы проектирования

1.1 Свойства безопасности

Сл. 4

Любое требование безопасности направлено на сохранение одного или нескольких свойств информации. Три основных свойства образуют триаду конфиденциальность–целостность–доступность (по первым буквам английских названий её называют CIA). Согласно международному стандарту ISO/IEC 27000 [3], **конфиденциальностью** называется свойство информации не предоставляться и не раскрываться неуполномоченным лицам, объектам или процессам; **целостностью** — свойство точности и полноты; **доступностью** — свойство находиться в состоянии готовности и возможности использования по запросу уполномоченного субъекта. Для каждого свойства известны типичные нарушения и меры защиты (таблица 2).

Таблица 2 — Свойства триады и их нарушения

Свойство	Что означает	Пример нарушения	Типовые меры
Конфиденциальность	Информация не раскрывается неуполномоченным	Утечка данных, перехват трафика	Шифрование, разграничение доступа, маскирование персональных данных
Целостность	Информация точна и полна	SQL-инъекция, подмена данных при передаче	Коды аутентичности сообщений, цифровые подписи, цепочки хешей
Доступность	Информация доступна по запросу уполномоченного субъекта	Отказ в обслуживании, программа-вымогатель	Резервирование, резервные копии, ограничение частоты запросов

Триада дополняется свойствами, связанными с ответственностью субъектов (таблица 3). Они важны, когда требуется не только защитить данные, но и доказать, кто и что сделал. Определения приведены по ISO/IEC 27000 [3].

Таблица 3 — Свойства, дополняющие триаду

Свойство	Что означает	Как обеспечивается
Неотказуемость	Способность удостоверить имевшее место действие или событие и его источники так, чтобы они не могли быть позднее отвергнуты	Цифровая подпись, журнал с защитой от изменения
Подлинность	Свойство, гарантирующее, что субъект или ресурс идентичен заявленному	Сертификаты, подписи, проверка отправителя

Сл. 5

Показательно, что одна уязвимость нарушает сразу несколько свойств. Так, в 2023 году через SQL-инъекцию в продукте MOVEit Transfer были похищены данные многих организаций (нарушена конфиденциальность), а в системы добавлялись скрытые учётные записи (нарушена целостность); часть организаций отключала сервис, что нарушало доступность.

1.2 Принципы проектирования

Сл. 6

В 1975 году Дж. Зальцер и М. Шрёдер сформулировали принципы построения защитных механизмов [4]. Они сформулированы для систем с разделением доступа, но остаются основой современных стандартов, в том числе NIST SP 800-160 [5], и применимы к облачным и сервисным архитектурам. Восемь принципов приведены в таблице 4.

Таблица 4 — Восемь принципов Зальцера и Шрёдера

Принцип	Суть	Пример
Экономия механизма	Защитный механизм прост и мал, поэтому его можно проверить	Одна централизованная служба аутентификации вместо пяти разных схем
Отказ по умолчанию	Доступ запрещён, пока не разрешён явно; при сбое система закрывается	Если проверка прав завершилась ошибкой, запрос отклоняется
Полное посредничество	Каждое обращение проверяется заново	Токен проверяется при каждом запросе, отзыв прав действует сразу
Открытый замысел	Безопасность не зависит от секретности устройства системы, секретен только ключ	Алгоритмы AES и TLS публичны, секретны ключи
Разделение привилегий	Критическая операция требует согласия нескольких субъектов	Код проходит рецензирование и утверждение до выпуска

Принцип	Суть	Пример
Наименьшие привилегии	Субъект получает только необходимые права	Сервис заказов читает таблицу пользователей и пишет только в таблицу заказов
Наименьший общий механизм	Минимум общих для разных пользователей средств	Отдельные базы данных и учётные записи для разных клиентов
Психологическая приемлемость	Защита проста в применении, иначе её обходят	Понятный вход с вторым фактором вместо сложной процедуры

Принцип открытого замысла восходит к правилу голландского криптографа О. Керкгоффса (1883): система должна оставаться безопасной, даже если всё, кроме ключа, известно противнику. Следствие: если утечка исходного кода приводит к взлому, то безопасность опиралась на секретность реализации, а не на устройство системы.

1.3 Защита в глубину

Сл. 7

К перечисленным принципам на практике добавляют защиту в глубину. Согласно определению NIST, **защитой в глубину** называется стратегия защиты информации, объединяющая возможности людей, технологий и операций для создания барьеров переменной стойкости на нескольких уровнях и в разных областях деятельности организации [6]. Для технических систем это несколько независимых уровней защиты, при которых отказ одного не приводит к полному взлому. Уровни показаны на рисунке 1 и описаны в таблице 5.

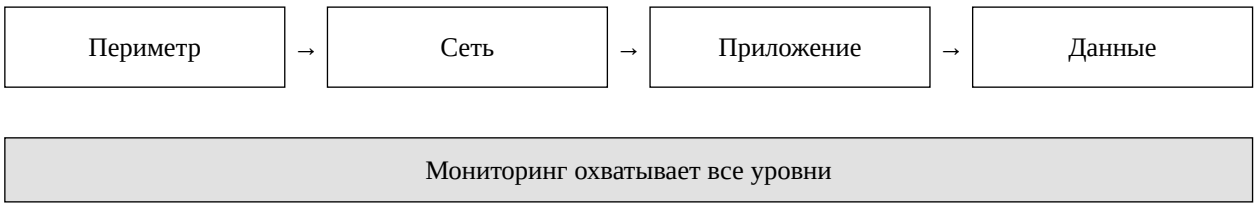


Рисунок 1 — Уровни защиты в глубину

Таблица 5 — Уровни защиты в глубину

Уровень	Средства	Что защищает
Периметр	Межсетевой экран, экран веб-приложений, защита от перегрузки	Фильтрация внешнего трафика
Сеть	Сегментация, шифрование обмена между сервисами, сетевые политики	Ограничение перемещения внутри сети
Приложение	Аутентификация и авторизация, проверка входных данных	Бизнес-логику
Данные	Шифрование при хранении и передаче, права на уровне базы данных	Сами данные
Мониторинг	Журналирование, обнаружение вторжений, анализ поведения	Обнаружение и реагирование

Для запроса к интерфейсу `/api/orders/{id}` уровни работают так: на периметре отсекаются известные шаблоны атак; шлюз проверяет токен и ограничивает частоту запросов; приложение проверяет, что заказ принадлежит пользователю; база данных принимает только параметризованные запросы; журнал фиксирует событие с идентификатором пользователя, заказа и адресом источника.

1.4 Нарушения принципов в реальных инцидентах

Сл. 8

Принципы проверяются практикой: каждый крупный инцидент можно описать как нарушение одного или нескольких из них (таблица 6).

Таблица 6 — Примеры нарушения принципов проектирования

Инцидент	Нарушенный принцип	Что произошло
Capital One, 2019	Наименьшие привилегии	Из-за ошибки настройки экрана веб-приложений и подделки запроса со стороны сервера (SSRF) нарушитель получил учётные данные роли с избыточным доступом к хранилищу и скопировал данные около 100 миллионов человек [7]
SolarWinds, 2020	Разделение привилегий	В среду сборки продукта внедрили закладку, и обновление с ней получили порядка 18 тысяч организаций [8]
Log4Shell, 2021	Экономия механизма	Библиотека журналирования умела выполнять поиск по внешним каталогам внутри записываемой строки, и строка от пользователя приводила к выполнению чужого кода (CVE-2021-44228)

2 Активы и поверхность атаки

2.1 Активы

Активом называется всё, что имеет ценность для организации [3]: данные, инфраструктура, сервисы, репутация. Защита строится вокруг активов, поэтому их перечень составляется первым. Для каждого актива указывается, какое из свойств безопасности критично (таблица 7): для секретов это конфиденциальность, для сервисов — доступность, для кода и конфигураций — целостность.

Таблица 7 — Классификация активов

Категория	Примеры	Критичность	Важнейшее свойство
Персональные данные	ФИО, паспортные данные, адрес электронной почты, телефон	Высокая	Конфиденциальность, целостность
Финансовые данные	Номера карт, счета, транзакции	Критическая	Все три свойства
Секреты	Ключи интерфейсов, пароли, закрытые ключи, ключи подписи токенов	Критическая	Конфиденциальность
Исходный код и конфигурации	Код, файлы описания инфраструктуры	Высокая	Целостность, конфиденциальность
Инфраструктура	Серверы, кластеры, конвейер сборки, облачные ресурсы	Высокая	Целостность, доступность
Сервисы	Интерфейсы, пользовательские приложения, интеграции с партнёрами	Средняя или высокая	Доступность, целостность
Процессы	Выпуск версий, резервное копирование, реагирование на инциденты	Средняя	Целостность, доступность

Сл. 10

В учебном магазине активами являются данные покупателей, платёжные операции, ключ доступа к платёжному сервису, каталог с ценами и сама работа сайта (таблица 8).

Таблица 8 — Активы учебного магазина

Актив магазина	Категория	Важнейшее свойство
Данные покупателей: ФИО, адрес, почта, история заказов	Персональные данные	Конфиденциальность
Платёжные операции и суммы	Финансовые данные	Целостность, конфиденциальность
Ключ доступа к платёжному сервису	Секрет	Конфиденциальность
Каталог товаров и цены	Данные	Целостность
Работа сайта	Сервис	Доступность

2.2 Поверхность атаки

Сл. 11

Поверхностью атаки называется множество точек на границе системы, элемента системы или среды, в которых нарушитель может попытаться проникнуть, оказать воздействие или извлечь данные [6]. К таким точкам относятся интерфейсы, пользовательские формы, порты, службы, учётные записи, а также люди. Чем больше таких точек, тем больше возможностей у нарушителя и тем труднее их контролировать. Набор доступных точек зависит от того, кто атакует. Нарушитель бывает **внешним**, если у него нет санкционированного доступа к системе, и **внутренним**, если такой доступ есть (пользователь, администратор, сотрудник подрядчика). Внешний нарушитель стремится найти точку входа, внутренний — выйти за пределы выданных прав. Точки входа и способы проникновения для каждого из них собраны в таблице 9.

Таблица 9 — Поверхность атаки внешнего и внутреннего нарушителя

Нарушитель	Точки входа	Способы проникновения	Как сокращается поверхность
Внешний	Службы и интерфейсы, доступные из интернета; электронная почта; сторонние библиотеки и обновления; сотрудники как цель обмана	Эксплуатация уязвимости публичной службы; подбор и подстановка учётных данных; инъекции и подделка запросов; фишинг; закладка в зависимости или обновлении	Единый шлюз, экран веб-приложений, закрытие неиспользуемых портов, подпись артефактов, второй фактор
Внутренний	Рабочие места, административные панели, внутренние интерфейсы, базы данных, носители, помещения	Злоупотребление выданными правами; повышение привилегий; перемещение между сервисами; вынос данных; физический доступ к оборудованию	Наименьшие привилегии, разделение привилегий, сегментация, журнал действий, шифрование дисков

Для внутреннего нарушителя размер поверхности быстро растёт с числом сервисов. Если сервис может обратиться к любому другому, то при N сервисах возможно порядка N^2 связей; если разрешены только необходимые связи, их число приблизительно равно числу реальных взаимодействий.

В магазине внешнему нарушителю доступны страница входа, форма заказа и приём ответов платёжного сервиса, а внутреннему — административная панель и база данных.

2.3 Сокращение поверхности атаки

Сл. 12

Систематический подход к сокращению поверхности атаки предложил М. Ховард (Microsoft). Он состоит из четырёх шагов (рисунок 2): перечисление всех точек входа (интерфейсы, формы, командные интерфейсы, задания по расписанию, административные и отладочные входы); классификация каждой по вопросам «кто может обратиться, какие данные принимает, каких прав требует»; сокращение лишнего; регулярный пересмотр, поскольку с каждым выпуском точки входа появляются снова.

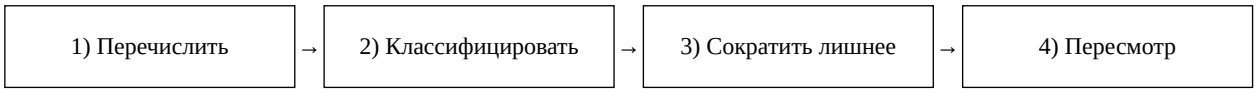


Рисунок 2 — Шаги сокращения поверхности атаки

Типичные меры сокращения и их эффект собраны в таблице 10.

Таблица 10 — Меры сокращения поверхности атаки

Мера	Было	Стало
Отключение отладочных входов	Отладочные интерфейсы доступны в рабочей среде	Удалены или доступны только из внутренней сети
Единый шлюз	Десятки сервисов доступны из интернета	Одна точка входа с проверкой подлинности
Сетевые политики	Каждый сервис может обращаться к любому	Разрешены только перечисленные пары
Защита служебных страниц	Страница состояния без проверки сообщает версию	Минимальный ответ, подробности только после входа

3 Границы доверия и диаграмма потоков данных

3.1 Границы доверия

Сл. 14

Границей доверия в методике моделирования угроз называется место, где при движении данных по системе меняется зона доверия [9]. Данные из интернета заслуживают меньшего доверия, чем данные внутри защищённого сегмента, поэтому на границе выполняются проверки: аутентификация, авторизация, проверка входных данных. Практическое правило: если для перехода между зонами требуется аутентификация или шифрование, это граница доверия. Типичные границы современных систем приведены в таблице 11.

Таблица 11 — Типичные границы доверия

Граница	Пример	Обязательные проверки	Типичные атаки
Клиент → сервер	Браузер → интерфейс	Шифрование TLS, проверка токена, проверка входных данных	Межсайтовые сценарии, подбор паролей, инъекции
Сервис → сервис	Серверная часть → база данных	Взаимная аутентификация, разграничение прав, параметризованные запросы	SSRF, SQL-инъекция, повышение привилегий
Внешняя система → наша	Интерфейс партнёра → шлюз	Ключ или OAuth, ограничение частоты, проверка формата	Злоупотребление интерфейсом, вывод данных
Конвейер сборки → рабочая среда	Сборка → кластер	Подпись артефактов, политики допуска	Атаки на цепочку поставки, подмена образа
Пользователь → администратор	Панель управления	Второй фактор, полный аудит, список разрешённых адресов	Повышение привилегий, захват учётной записи
Облако → локальная сеть	Облачный сервис → корпоративная сеть	VPN или доступ с проверкой личности, межсетевой экран	Перемещение внутри сети, кража учётных данных

3.2 Диаграмма потоков данных

В методике моделирования угроз Microsoft основным артефактом анализа служит **диаграмма потоков данных** (DFD) [9]: схема, на которой показаны элементы системы и данные, передаваемые между ними. Она делает видимыми все места, где данные пересекают границы доверия. Диаграмма

строится на нескольких уровнях: на нулевом система показана одним процессом вместе с внешними сущностями; на первом раскрыты основные компоненты (клиентская часть, серверная часть, база данных, очередь, внешние сервисы); на втором при необходимости детализируются отдельные компоненты.

Сл. 15

Диаграмма строится из элементов пяти видов (таблица 12). Для каждого вида далее будут определены типичные угрозы (п. 4.3).

Таблица 12 — Элементы диаграммы потоков данных

Элемент	Обозначение	Что означает
Внешняя сущность	Прямоугольник	Пользователь или внешняя система за пределами нашего контроля
Процесс	Круг	Компонент, который обрабатывает данные: сервис, функция
Хранилище данных	Две параллельные линии	База данных, файловая система, кэш
Поток данных	Стрелка	Передача данных между элементами
Граница доверия	Пунктирная линия	Место смены уровня доверия

Сл. 16

Диаграмма учебного магазина показана на рисунке 3: покупатель и администратор обращаются к веб-приложению из интернета, приложение обращается к базе данных во внутренней сети и к внешнему платёжному сервису. На диаграмме три границы доверия и четыре потока (запросы покупателя, запросы администратора, SQL-запросы и платёжные запросы); именно на них будут искаться угрозы.

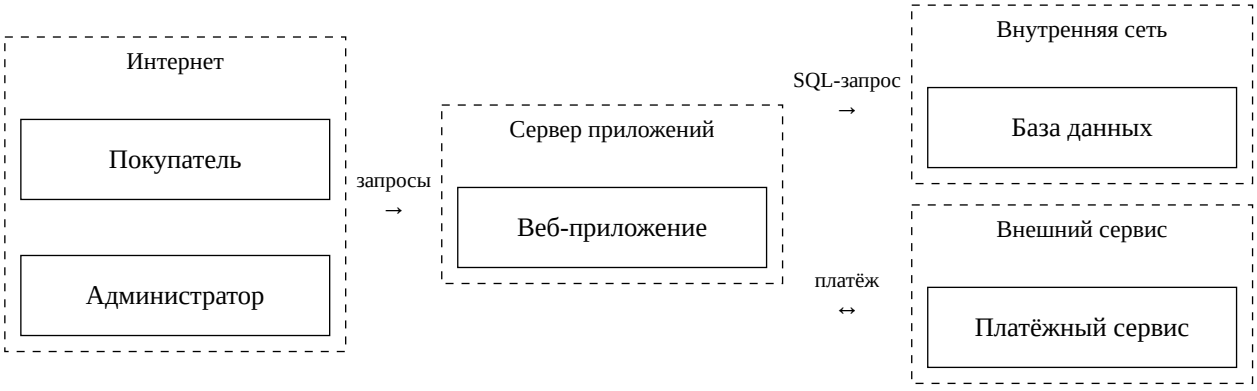


Рисунок 3 — Диаграмма потоков данных учебного магазина (пунктиром отмечены границы доверия)

4 Модель нарушителя и угрозы

4.1 Модель нарушителя

Сл. 18

Нарушителем (в англоязычной терминологии — adversary) называется лицо, группа, организация или государство, которые осуществляют или намереваются осуществлять вредоносную деятельность [10]. Описание типовых нарушителей по мотивации, ресурсам и действиям, которое показывает, кто может атаковать систему, с какой целью и какими средствами, называют моделью нарушителя. Без неё невозможно расставить приоритеты угроз и разумно распределить затраты на защиту: система, рассчитанная на массовые автоматические сканирования, и система, защищаемая от государственной группировки, строятся по-разному. Типовые нарушители собраны в таблице 13.

Таблица 13 — Типовые нарушители

Нарушитель	Мотивация	Ресурсы	Типичные действия
Начинающий нарушитель	Любопытство, развлечение	Низкие	Готовые эксплойты, сканеры
Активист	Идеология, протест	Низкие или средние	Перегрузка, подмена содержимого сайта, публикация данных
Организованная преступность	Финансовая выгода	Средние или высокие	Программы-вымогатели, мошенничество с почтой, подстановка украденных паролей
Государственная группировка	Шпионаж, разрушение	Очень высокие	Неизвестные уязвимости, атаки на цепочку поставки, специальное вредоносное ПО
Внутренний нарушитель	Месть, выгода	Высокие (есть доступ)	Вывод данных, саботаж, скрытые входы
Невнимательный сотрудник	Нет умысла	Доступ без злого умысла	Ошибки настройки, утечка секретов

Сл. 19

Кроме принадлежности к внешним или внутренним, нарушителей различают по **потенциалу** — совокупности знаний, ресурсов и мотивации, которые необходимы для реализации атаки. Международная методика оценки (Common Criteria) выделяет четыре уровня: базовый, базовый повышенный, средний и высокий; в российской практике им соответствуют обозначения Н1–Н4 (таблица 14). Один и тот же нарушитель может быть внешним или внутренним при любом потенциале: например, внешний нарушитель, получивший учётную запись сотрудника, действует как внутренний.

Таблица 14 — Потенциал нарушителя

Обозначение	Потенциал	Что умеет нарушитель
H1	Базовый	Использует готовые средства и общеизвестные уязвимости, специальных знаний не требуется
H2	Базовый повышенный	Изменяет готовые средства, комбинирует несколько уязвимостей
H3	Средний	Самостоятельно ищет уязвимости, в том числе анализом кода, и создаёт собственные средства
H4	Высокий	Внедряет закладки в программное и аппаратное обеспечение, располагает ресурсами организации или государства

4.2 Сценарии атак

Сл. 20

Для описания последовательности действий нарушителя применяется модель **цепочки целевой атаки** (Cyber Kill Chain) компании Lockheed Martin [11]. Она делит атаку на семь этапов (рисунок 4): разведка, подготовка средств, доставка, эксплуатация уязвимости, закрепление в системе, управление и достижение цели. Ценность модели в том, что она показывает, на каком этапе атаку можно заметить и остановить: чем раньше, тем меньше ущерб.

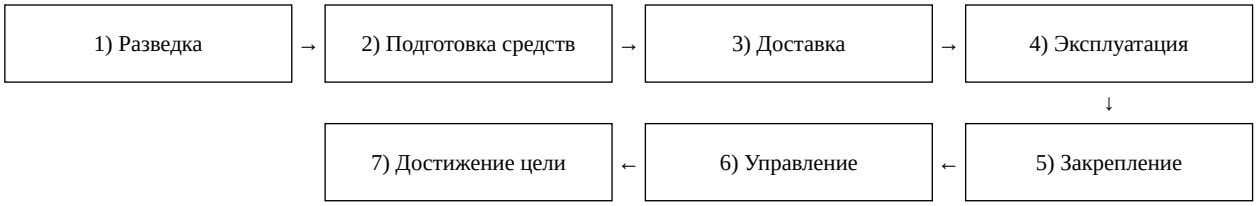


Рисунок 4 — Семь этапов цепочки целевой атаки

Сл. 21

Более подробное описание даёт база знаний **MITRE ATT&CK**: в ней тактики (цели нарушителя на каждом этапе) разложены на техники и подтехники, привязанные к реальным группировкам и инструментам [12]. Для матрицы корпоративных систем определено 14 тактик. Соответствие этапов цепочки тактикам и средства обнаружения приведены в таблице 15.

Таблица 15 — Цепочка атаки и тактики ATT&CK

Этап цепочки	Тактика ATT&CK	Пример техники	Средства обнаружения
Разведка	Reconnaissance (TA0043)	Active Scanning (T1595)	Журналы экрана веб-приложений, приманки
Доставка	Initial Access (TA0001)	Phishing (T1566), Valid Accounts (T1078)	Почтовый шлюз, журналы второго фактора

Этап цепочки	Тактика ATT&CK	Пример техники	Средства обнаружения
Эксплуатация	Execution (TA0002)	Command and Scripting Interpreter (T1059)	Защита конечных точек, журналы приложений
Закрепление	Persistence (TA0003)	Scheduled Task/Job (T1053)	Аудит системы, журналы запуска процессов
Управление	Command and Control (TA0011)	Application Layer Protocol (T1071)	Анализ DNS и прокси
Достижение цели	Exfiltration (TA0010)	Exfiltration Over C2 Channel (T1041)	Контроль утечек, анализ поведения

4.3 Классификация угроз STRIDE

Сл. 22

Угрозой называется потенциальная причина нежелательного инцидента, который может нанести ущерб системе или организации [3]. Для систематического поиска угроз применяется классификация **STRIDE** (Microsoft), в которой название составлено из первых букв шести типов угроз; каждый тип нарушает определённое свойство безопасности (таблица 16) [13].

Таблица 16 — Классификация угроз STRIDE

Буква	Угроза	Нарушаемое свойство	Пример
S	Spoofing — подмена личности	Подлинность	Использование украденного пароля или поддельного токена
T	Tampering — изменение данных	Целостность	Изменение суммы платежа при передаче
R	Repudiation — отказ от действия	Неотказуемость	Администратор отрицает удаление записей
I	Information disclosure — раскрытие информации	Конфиденциальность	Дамп базы данных через уязвимость
D	Denial of service — отказ в обслуживании	Доступность	Поток запросов на страницу входа
E	Elevation of privilege — повышение привилегий	Авторизация	Обычный пользователь выполняет административную функцию

Сл. 23

Применяется STRIDE к элементам диаграммы потоков данных: для каждого элемента проверяются не все шесть типов, а только те, которые к нему относятся (таблица 17). Например, повышение привилегий возможно только у процесса, потому что только процесс выполняет действия с правами.

Таблица 17 — Применимость типов угроз к элементам диаграммы (* только для хранилищ журналов)

Элемент	S	T	R	I	D	E
Внешняя сущность	✓		✓			
Процесс	✓	✓	✓	✓	✓	✓
Хранилище данных		✓	✓*	✓	✓	
Поток данных		✓		✓	✓	

Сл. 24

Результатом применения служит перечень угроз. Для диаграммы на рисунке 3 он приведён в таблице 18; номера угроз сохраняются во всех следующих таблицах.

Таблица 18 — Перечень угроз учебного магазина

№	Элемент	Тип	Сценарий
У1	Веб-приложение (процесс)	S	Нарушитель подбирает пароль покупателя на странице входа
У2	База данных (хранилище)	T, I	SQL-инъекция через непроверенный ввод в форме поиска
У3	Веб-приложение (процесс)	I, E	Покупатель подставляет номер чужого заказа и получает его данные
У4	Веб-приложение (процесс)	D	Поток запросов к странице входа выводит сайт из строя
У5	Администратор (сущность)	R	Администратор отрицает смену цены товара
У6	Платёжный запрос (поток)	T	Нарушитель изменяет сумму в запросе к платёжному сервису

4.4 Оценка рисков

Сл. 25

Угроз обычно больше, чем ресурсов на их закрытие, поэтому их ранжируют по **риску**. Согласно ISO/IEC 27000 [3], риском называется влияние неопределённости на цели; его часто выражают сочетанием последствий события и вероятности их наступления. Простейший способ — оценить обе величины по трёхбалльной шкале и перемножить (таблица 19): оценки 1–2 соответствуют низкому риску, 3–4 среднему, 6–9 высокому. Оценки в примере условные: на практике их назначает команда по данным о системе.

Таблица 19 — Ранжирование угроз учебного магазина

№	Угроза	Вероятность	Воздействие	Риск	Уровень
У1	Подбор пароля	3	2	6	Высокий
У2	SQL-инъекция	2	3	6	Высокий
У3	Доступ к чужим заказам	3	3	9	Высокий
У4	Отказ в обслуживании	2	2	4	Средний
У5	Отрицание изменения цены	1	2	2	Низкий
У6	Подмена суммы платежа	1	3	3	Средний

Кроме этого способа, для оценки тяжести конкретных уязвимостей применяется стандарт CVSS [14], для разложения цели нарушителя на пути её достижения — деревья атак, для угроз приватности — методика LINDDUN.

5 Архитектура нулевого доверия

5.1 Предпосылки

Сл. 27

Традиционная модель исходила из того, что внутри периметра сети находятся доверенные участники, а снаружи — недоверенные. Эта модель не работает, когда ресурсы размещены в облаке, сотрудники работают удалённо, а атаки идут через цепочку поставки, как в случае SolarWinds. Нарушитель, оказавшийся внутри сети, свободно перемещается и достигает ценных систем без дополнительных проверок. Согласно NIST SP 800-207 [15], **нулевым доверием** (Zero Trust) называется набор концепций и идей, предназначенных для минимизации неопределённости при принятии точных решений о доступе с наименьшими привилегиями по каждому запросу в информационных системах и службах, когда сеть считается скомпрометированной. Местонахождение в сети не даёт доверия, каждое обращение проверяется отдельно, а архитектура, построенная на этих концепциях, называется архитектурой нулевого доверия. Основные отличия от периметровой модели приведены в таблице 20.

Таблица 20 — Периметровая модель и нулевое доверие

Аспект	Периметровая модель	Нулевое доверие
Доверие	Внутри сети доверенный	Никто не доверен по умолчанию
Проверка	Вход в сеть (VPN, домен)	Каждое обращение к ресурсу
Сегментация	Сети и межсетевые экраны	Мелкая сегментация по идентичности
Перемещение внутри сети	Свободное	Каждый переход проверяется
Видимость	На периметре	Журнал каждого обращения
Слабость	Один взлом открывает всё	Сложность внедрения

5.2 Положения архитектуры нулевого доверия

Сл. 28

Стандарт формулирует семь положений (таблица 21).

Таблица 21 — Положения нулевого доверия по NIST SP 800-207

№	Положение	Смысл
1	Все источники данных и вычислительные службы считаются ресурсами	Нет «особых» систем вне защиты
2	Весь обмен защищён независимо от расположения в сети	Внутренняя сеть не считается безопасной
3	Доступ к ресурсу предоставляется на один сеанс	Нет постоянного доверия

№	Положение	Смысл
4	Доступ определяется динамической политикой: идентичность, состояние устройства, поведение	Учитывается контекст запроса
5	Организация следит за целостностью и состоянием защищённости своих устройств	Недоверие к «ненадёжному» устройству
6	Аутентификация и авторизация динамические и выполняются до предоставления доступа	Проверка перед доступом, а не после
7	Организация собирает сведения о состоянии ресурсов и обмена и использует их для улучшения защиты	Журналы улучшают политики

5.3 Компоненты архитектуры

Сл. 29

Решение о доступе принимают три логических компонента (рисунок 5): **механизм политик** (Policy Engine) решает, предоставить ли доступ; **администратор политик** (Policy Administrator) создаёт или закрывает сеанс по этому решению; **точка применения политик** (Policy Enforcement Point) расположена на пути трафика и пропускает или блокирует обращение. Субъект не получает доступ к ресурсу напрямую: все обращения проходят через точку применения.



Рисунок 5 — Логические компоненты нулевого доверия

Для принятия решения компоненты используют вспомогательные системы (таблица 22).

Таблица 22 — Вспомогательные компоненты нулевого доверия

Компонент	Функция	Типовая реализация
Механизм политик	Решение о доступе по политикам	OPA, Cedar, собственный обработчик правил
Администратор политик	Выполнение решения, управление сеансами	Контроллер сервисной сетки, контроллер ZTNA
Точка применения политик	Пропуск или блокировка обращения	Прокси Envoy, шлюз интерфейсов, агент
Поставщик идентичности	Аутентификация субъектов	Keycloak, Okta, Azure AD
Журналирование и анализ	Контроль и обнаружение аномалий	Elastic, Splunk, Wazuh
Учёт ресурсов	Инвентаризация активов	NetBox, CMDB
Сведения об угрозах	Обогащение контекста	MISP, коммерческие потоки

5.4 Применение к учебному магазину

Сл. 30

Для учебного магазина нулевое доверие означает следующее. Запросы администратора проверяются так же строго, как запросы покупателя: каждое обращение к заказу проверяет владельца (угроза У3), а действия администратора требуют второго фактора и записываются в журнал (угроза У5). Приложение получает от базы данных только необходимые права, поэтому последствия инъекции ограничены (угроза У2). Платёжный сервис принимает только подписанные запросы с проверкой суммы (угроза У6).

6 Требования безопасности

6.1 Источники требований

Сл. 32

Требования безопасности не придумываются «из головы»: их берут из нескольких источников, расположенных по убыванию общности (таблица 23).

Таблица 23 — Источники требований безопасности

Источник	Что даёт	Пример
Бизнес и договоры	Обязательства перед клиентами и партнёрами	Защита платёжных данных, соглашения об уровне услуг
Отраслевые стандарты	Проверенные перечни мер	OWASP ASVS, ISO 27001, NIST Cybersecurity Framework, CIS Controls
Моделирование угроз	Меры против конкретных угроз системы	Для каждой угрозы STRIDE: мера, способ проверки, метрика
Внутренние политики	Правила организации	Доступность 99,9 %, сроки хранения данных, порядок реагирования

6.2 Стандарт OWASP ASVS

Сл. 33

OWASP ASVS (Application Security Verification Standard) — по описанию проекта OWASP, основа для проверки технических мер безопасности веб-приложений, а также перечень требований к безопасной разработке [16]. Версия 5.0 (2025) содержит около 350 требований в 17 главах и три уровня проверки: первый подходит для любых приложений, второй — для приложений с конфиденциальными данными, третий — для критических систем (медицина, финансы). Уровни накопительные: требования третьего уровня включают требования первого и второго. Примеры глав приведены в таблице 24.

Таблица 24 — Избранные главы OWASP ASVS 5.0

Глава	Тема	Пример требования
V6	Аутентификация	Стойкие пароли, второй фактор, защита от перебора
V7	Управление сеансами	Ограниченное время жизни, смена идентификатора после входа
V8	Авторизация	Запрет по умолчанию, проверка владельца объекта
V11	Криптография	Современные алгоритмы, управление ключами
V12	Защищённый обмен	TLS для всего обмена
V13	Конфигурация	Удаление учётных данных по умолчанию, отключение отладки
V14	Защита данных	Классификация, минимизация, маскирование
V16	Журналирование и обработка ошибок	Запись событий безопасности, защита журнала

6.3 Формулировка требований

Сл. 34

Хорошее требование безопасности обладает четырьмя свойствами (таблица 25): оно конкретно, проверяемо, прослеживаемо до угрозы или стандарта и измеримо в эксплуатации.

Таблица 25 — Свойства требования безопасности

Свойство	Что требуется	Пример
Конкретность	Что именно реализовать	Блокировка после 5 неудачных входов за 15 минут
Проверяемость	Как подтвердить выполнение	Тест: шесть запросов с неверным паролем, на шестой ответ HTTP 429
Прослеживаемость	К какой угрозе или пункту стандарта относится	Подбор пароля (STRIDE: подмена личности)
Измеримость	Какая метрика покажет работу в эксплуатации	Число блокировок в сутки

Полная формулировка по одной угрозе содержит шесть элементов: угрозу (У1: подбор пароля на входе, подмена личности); требование (блокировка после пяти неудач за 15 минут); реализацию (счётчик неудач с ограниченным сроком жизни); проверку (автоматический тест на шесть запросов); событие журнала (`auth.lockout` с идентификатором пользователя, адресом, временем и числом попыток); метрику (число блокировок, оповещение при превышении порога).

6.4 Процесс моделирования угроз

Сл. 35

Моделированием угроз называется форма оценки рисков, в которой моделируются аспекты атаки и защиты логического объекта: данных, приложения, узла, системы или среды [6]. На практике оно объединяет приёмы предыдущих глав в одну последовательность из девяти шагов (рисунок 6): определить объект анализа; построить диаграмму потоков данных; отметить границы доверия; применить STRIDE к элементам; оценить риски; определить меры; определить способы проверки; определить события журнала для обнаружения; зафиксировать всё в итоговой таблице.

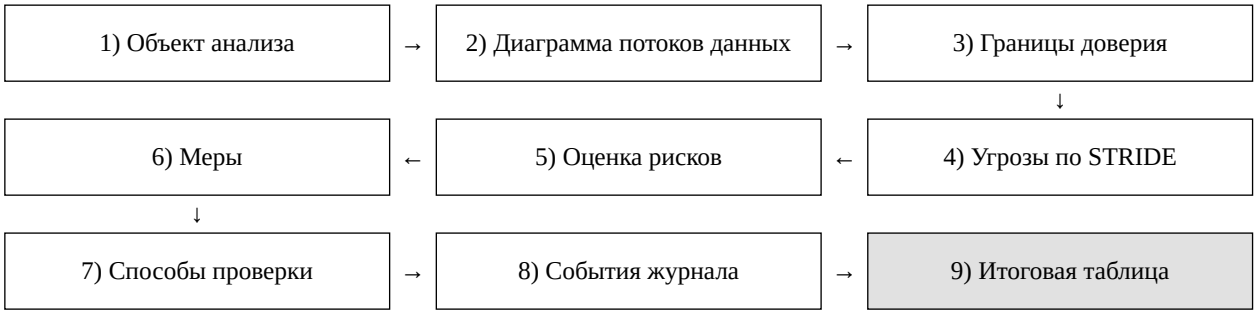


Рисунок 6 — Девять шагов моделирования угроз

Сл. 36

Итог процесса — таблица, связывающая угрозу с мерой, проверкой и событием журнала (таблица 26). Для учебного магазина она строится из угроз У1–У6, найденных на диаграмме и оценённых выше. Таблица передаётся разработчикам как набор требований и службе мониторинга как перечень событий для обнаружения.

Таблица 26 — Итоговая таблица «угроза — мера — проверка — событие» учебного магазина

Угроза	Тип	Риск	Мера	Проверка	Событие
У1. Подбор пароля	S	Высокий	Второй фактор, ограничение частоты, блокировка	Шесть неверных попыток → блокировка	`auth.lockout`
У2. SQL-инъекция	T, I	Высокий	Запросы с параметрами, экран веб-приложений	Статический анализ, проверка sqlmap	`waf.block.sqli`
У3. Доступ к чужим заказам	I, E	Высокий	Проверка владельца заказа	Запрос чужого заказа → 403	`authz.denied`
У4. Отказ в обслуживании	D	Средний	Ограничение частоты, сеть доставки	Нагрузочный тест	`rate.exceeded`

Угроза	Тип	Риск	Мера	Проверка	Событие
У5. Отрицание изменения цены	R	Низкий	Журнал с защитой от изменения, второй фактор	Изменение цены → запись с автором	`admin.price_change`
У6. Подмена суммы платежа	T	Средний	Подпись запроса, сверка суммы	Изменённая сумма → отказ	`payment.mismatch`

Для построения диаграмм и перечней угроз применяются Microsoft Threat Modeling Tool, OWASP Threat Dragon, Threagile (модель угроз как код в формате YAML), коммерческий IriusRisk или обычный редактор схем.

ЗАКЛЮЧЕНИЕ

Сл. 37

Основные положения лекции собраны в таблице 27.

Таблица 27 — Основные положения лекции

Глава	Главное
1. Свойства и принципы	Конфиденциальность, целостность, доступность; восемь принципов Зальцера и Шрёдера; защита в глубину
2. Активы и поверхность	Защита строится вокруг активов; поверхность атаки сокращают и пересматривают
3. Границы доверия	Проверки выполняются там, где меняется уровень доверия; граница видна на диаграмме потоков данных
4. Нарушитель и угрозы	Модель нарушителя, цепочка атаки, STRIDE по элементам, ранжирование по риску
5. Нулевое доверие	Каждое обращение проверяется; решение принимают механизм политик, администратор политик, точка применения
6. Требования	Требование конкретно, проверяемо, прослеживаемо и измеримо; итог — таблица «угроза — мера — проверка — событие»

На практическом занятии 1 для описания учебной системы выполняется полный цикл: диаграмма потоков данных, угрозы по STRIDE, оценка рисков, таблица «угроза — мера — проверка — событие» и перечень требований безопасности.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Anderson R. Security Engineering: A Guide to Building Dependable Distributed Systems. 3-е изд. Wiley, 2020.
2. Federal Trade Commission. Equifax Data Breach Settlement [Электронный ресурс]. 2019. URL: https://www.ftc.gov/enforcement/refunds/equifax-data-breach-settlement.
3. ISO/IEC. ISO/IEC 27000:2018. Information technology — Security techniques — Information security management systems — Overview and vocabulary. 2018.
4. Saltzer J. H., Schroeder M. D. The Protection of Information in Computer Systems // Proceedings of the IEEE. 1975. Т. 63, № 9. Сс. 1278–1308.
5. National Institute of Standards and Technology. Engineering Trustworthy Secure Systems: technical report SP 800-160 Vol. 1 Rev. 1. 2022.
6. National Institute of Standards and Technology. Security and Privacy Controls for Information Systems and Organizations: technical report SP 800-53 Rev. 5. 2020.
7. U.S. Department of Justice. Seattle Tech Worker Arrested for Data Theft Involving Large Financial Services Company [Электронный ресурс]. 2019. URL: https://www.justice.gov/usao-wdwa/pr/seattle-tech-worker-arrested-data-theft-involving-large-financial-services-company.
8. CISA. Alert AA20-352A: Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations [Электронный ресурс]. 2020. URL: https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a.
9. Microsoft. Data-flow diagram elements. Microsoft Learn: Threat modeling [Электронный ресурс]. URL: https://learn.microsoft.com/en-us/training/modules/tm-create-a-threat-model-using-foundational-data-flow-diagram-elements/1b-elements.
10. National Institute of Standards and Technology. Guide for Conducting Risk Assessments: technical report SP 800-30 Rev. 1. 2012.

11. Hutchins E. M., Cloppert M. J., Amin R. M. Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains: technical report. 2011.

12. MITRE. MITRE ATT&CK [Электронный ресурс]. URL: https://attack.mitre.org/.

13. Shostack A. Threat Modeling: Designing for Security. Wiley, 2014.

14. FIRST. Common Vulnerability Scoring System, version 4.0: Specification Document [Электронный ресурс]. 2023. URL: https://www.first.org/cvss/v4-0/.

15. Rose S. и др. Zero Trust Architecture: technical report SP 800–207. 2020.

16. OWASP Foundation. Application Security Verification Standard (ASVS), version 5.0 [Электронный ресурс]. 2025. URL: https://owasp.org/www-project-application-security-verification-standard/.

ПРИЛОЖЕНИЕ А

Вопросы для самопроверки

Каждый вопрос сопровождается кратким ответом, составленным по материалу лекции.

1. Назовите пять из восьми принципов Зальцера и Шрёдера и приведите пример нарушения каждого.

Ответ. Например: наименьшие привилегии (Capital One: роль с избыточным доступом к хранилищу); разделение привилегий (SolarWinds: закладка попала в сборку без независимой проверки); экономия механизма (Log4Shell: лишняя функция поиска в библиотеке журналирования); отказ по умолчанию (при сбое проверки прав запрос должен отклоняться, а не пропускаться); полное посредничество (токен проверяется при каждом запросе, а не только при входе).

2. Чем граница доверия отличается от периметра сети?

Ответ. Периметр сети отделяет «внутреннее» от «внешнего» и считает внутреннее доверенным. Граница доверия проходит везде, где меняется уровень доверия, в том числе внутри периметра: между сервисом и базой данных, между пользователем и администратором. Поэтому границ в системе больше, чем периметров.

3. Для чего нужна модель нарушителя и как она помогает расставить приоритеты?

Ответ. Она определяет, от кого и какими средствами защищаются: ресурсы, мотивацию и доступ нарушителя. Угрозы, которые реализуют вероятные для системы нарушители, получают высокий приоритет; невозможные для них атаки не требуют затрат.

4. В чём разница между STRIDE и оценкой рисков и на каком шаге применяется каждое?

Ответ. STRIDE классифицирует угрозы и применяется для их поиска (шаг 4 моделирования). Оценка риска (вероятность и воздействие, CVSS) определяет, какие угрозы важнее, и применяется после поиска (шаг 5).

5. Назовите три логических компонента нулевого доверия и их функции.

Ответ. Механизм политик принимает решение о доступе; администратор политик выполняет решение, создавая или закрывая сеанс; точка применения политик стоит на пути трафика и пропускает или блокирует обращение.

6. Какие главы OWASP ASVS наиболее важны для приложения с интерфейсом API? Обоснуйте.

Ответ. Аутентификация и авторизация (V6, V8) — они защищают от подмены личности и доступа к чужим данным; защищённый обмен (V12) и конфигурация (V13); журналирование (V16), без которого атаки не обнаруживаются. Выбор обосновывается угрозами из таблицы STRIDE для конкретной системы.

7. Почему повышение привилегий (E) применимо только к процессам?

Ответ. Повышение привилегий означает выполнение действий с правами, которых у субъекта нет, а действия выполняют только процессы. Внешняя сущность, хранилище и поток данных сами ничего не выполняют, поэтому для них эта угроза не определена.

8. Как требование «защита от подбора пароля» превратить в проверяемое?

Ответ. Указать число и интервал («блокировка после 5 неудач за 15 минут»), способ проверки (шесть запросов с неверным паролем, на шестой ответ HTTP 429), событие журнала (`auth.lockout`) и метрику (число блокировок в сутки). Тогда требование можно реализовать, проверить и наблюдать в эксплуатации.

9. По диаграмме учебного магазина назовите три угрозы и укажите тип STRIDE каждой.

Ответ. Например: подбор пароля покупателя на странице входа (У1) — подмена личности (S); поток запросов к странице входа (У4) — отказ в обслуживании (D); изменение суммы в запросе к платёжному сервису (У6) —

изменение данных (T). Для каждой угрозы затем определяются мера, проверка и событие журнала.